SMART CONTRACT DUE DILIGENCE · SOLANA

Luck.io

Provably fair, or provably centralized? Testing the casino's core claims

Period covered
Tested July 2025

Prepared by
Ritik Jain, CCAI · CCI · CALM

3 of 9
anonymous signers can change vault logic

1
program owns every user's vault

0
public source code

17
marketing claims tested

Public sample of client work. Private individuals' names are withheld and wallet addresses are shortened.

1. Executive summary

Luck.io markets itself as a non-custodial Solana casino: players keep "exclusive control" of funds in a personal Smart Vault, and games are "provably fair". I opened a vault, inspected it on-chain, traced who controls it, compared the audited code with what is deployed, and checked each claim against the chain.

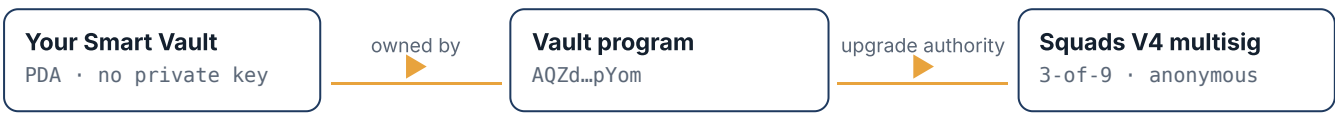
FINDING	EVIDENCE	CONFIDENCE
Smart Vaults are program-owned accounts with no private key. The player can't sign for them.	Account data	Deterministic
Every vault is controlled by one upgradeable program, whose upgrade key is a 3-of-9 anonymous multisig.	Program upgrade authority	Deterministic
The source code is not public, and the audited build does not match the deployed program.	Hash comparison	Deterministic
Settlement and game results are triggered off-chain by backend wallets; no on-chain randomness proofs were found.	Security audit, transaction review	Reported

> **Bottom line: player funds sit in accounts the team can change through a 3-of-9 multisig, and neither the custody claims nor the fairness claims can be verified on-chain.**

2. Scope and method

1. Deposited to a test Smart Vault and read the account on-chain: on-curve check and owner field.
2. Traced ownership from the vault to the program and to the program's upgrade authority.
3. Checked whether the source is public and compared the audited build hash with the deployed program using OtterSec's verification API.
4. Read the Halborn security audit to see which actions happen off-chain.
5. Tested each marketing claim and gave it a verdict: true, partly true, unverifiable or false.

3. How the vault is controlled



My own test vault (owner 9oHe...VcEJ, itself a program address) and every other vault checked lead back to the same program.

A program-derived address (PDA) is an account with no private key, so nobody signs for it directly; the program's code decides what can happen to it. Because the program is upgradeable, whoever holds the upgrade authority can deploy new code. Here that is a Squads V4 multisig where any 3 of 9 anonymous signers can approve an upgrade.

With 3 signatures the team could deploy a new vault program that restricts or delays withdrawals, freezes sessions, redirects funds, or changes vault rules at any time.

4. Claim-by-claim verdicts

Custody and control

CLAIM	VERDICT	WHY
"You retain exclusive control of your funds at all times."	False	Funds sit in a program-owned account you can't sign for.
"Luck.io cannot move or freeze your funds."	False	An upgrade approved by 3 of 9 signers can change what the vault allows.
"Your funds never leave your control."	False	Control is with the program and its upgrade authority.
"The vault only recognizes the player's wallet signature."	Unverifiable	Closed source; logic can be replaced by an upgrade.
"The casino never gains access to your money."	False	The team controls the code that governs the vault.
"If Luck.io goes offline, you can still access your funds."	Unverifiable	No public code or tested withdrawal path.
"No one, not even the team, can touch your assets."	False	The upgrade authority can.

Smart contracts and code

CLAIM	VERDICT	WHY
"All transactions are handled by verifiable smart contracts."	Partly true	Contracts run on-chain, but the code was shared privately with the auditor and the audited hash doesn't match the deployed program.
"No human can interfere."	False	Backend wallets trigger settlement; upgrades need human signers.
"Funds only flow to and from the depositing wallet."	Unverifiable	No public code; an upgrade could change routing.
"Settlement is automatic, instant and done by smart contracts."	Partly true	The audit shows settle_user_gain / settle_user_loss are called by backend wallets.
"The vault contract is fully governed by your wallet."	False	It is governed by the multisig upgrade authority.
"You can interact with the contract from any explorer or CLI."	Unverifiable	Without public code and IDL this can't be checked.
"Luck.io is fully decentralized and accountless."	False	Central multisig and off-chain backend.

Randomness and fairness

CLAIM	VERDICT	WHY
"Multiple independent oracles generate randomness and publish signatures on-chain."	Unverifiable	No oracle list, no oracle addresses, no readable randomness signatures on-chain.
"No one, not even Luck.io, can tamper with results."	Unverifiable	Results are computed off-chain and submitted by backend wallets; the team could submit, delay or replay results.
"Provably fair via the Proov Protocol."	Unverifiable	The protocol is closed-source.

5. What would make the claims true

- Publish the program source and a verifiable build whose hash matches the deployed program.
- Make the vault program immutable, or put upgrades behind a public timelock so users can withdraw before changes take effect.
- Name the multisig signers or move the upgrade authority to a public governance process.
- Publish oracle addresses and post randomness proofs on-chain for every game round.

6. Limitations

- I did not see the private source code; conclusions rely on on-chain data and the published audit.
- No funds were seen being misused. The finding is about who could change the rules, not that they did.

Confidence key

Deterministic	Directly visible on-chain or in a primary record. Anyone can verify it.
Probabilistic	Strong attribution from several linked pieces of evidence.
Heuristic	An inference from a repeated pattern. Treat as a lead, not a fact.
Reported	From a third party: an audit, a court filing, a public statement or user complaints.

About this sample. This is a public, redacted version of client work by INVESTIGATAH. Names of private individuals and promoters are withheld, and wallet addresses are shortened. The client version includes full addresses, transaction hashes and the screenshot evidence behind every finding.

Provably Fair or Provably Centralized? Investigating Luck.io's Core Claims

What is Luck.io?

Luck.io is a **non-custodial, on-chain crypto casino** built on the **Solana blockchain**. It allows players to deposit, gamble, and withdraw funds directly from their wallets, without traditional account logins or KYC requirements. According to its advocates, the platform leverages transparent smart contracts and provably fair gameplay using a system called the Proov Protocol

Core Claims Made by Luck.io

1) Custody & Control Claims

   "You retain exclusive control of your funds at all times."

   "Your Smart Vault is self-custodial — Luck.io cannot move or freeze your funds."

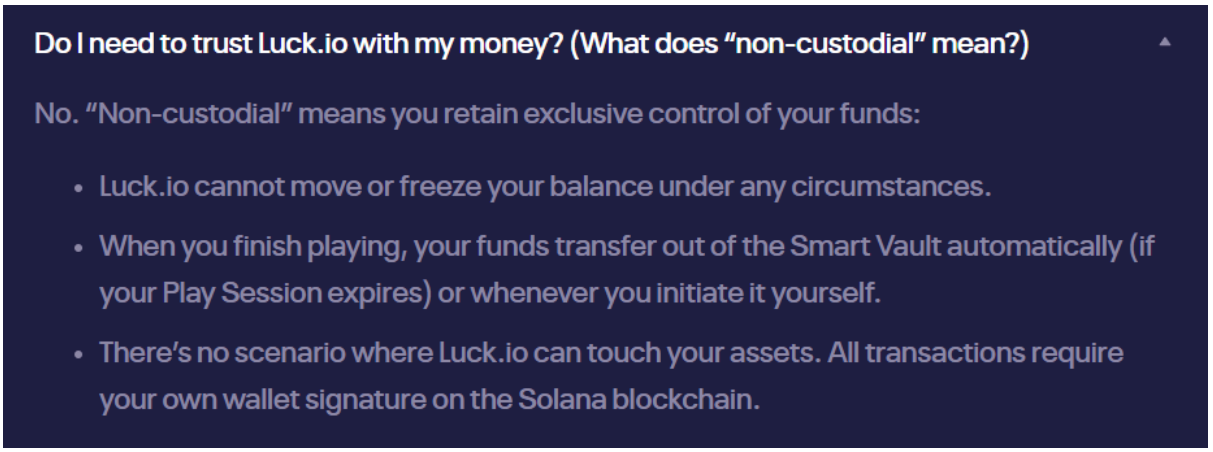
   "Your funds never leave your control."

   "The vault only recognizes the player's wallet signature."

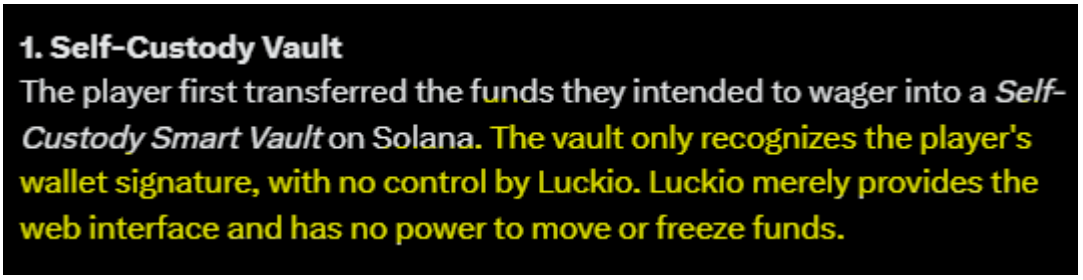
   "The casino never gains access to your money — not even temporarily."

   "If Luck.io goes offline, you can still access your funds."

   "No one not even the team can touch your assets."







Reality -

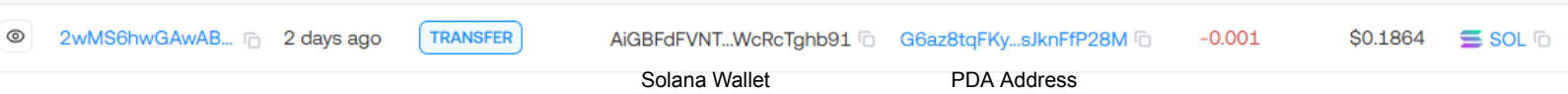
Claim 1: "You retain exclusive control of your funds at all times."

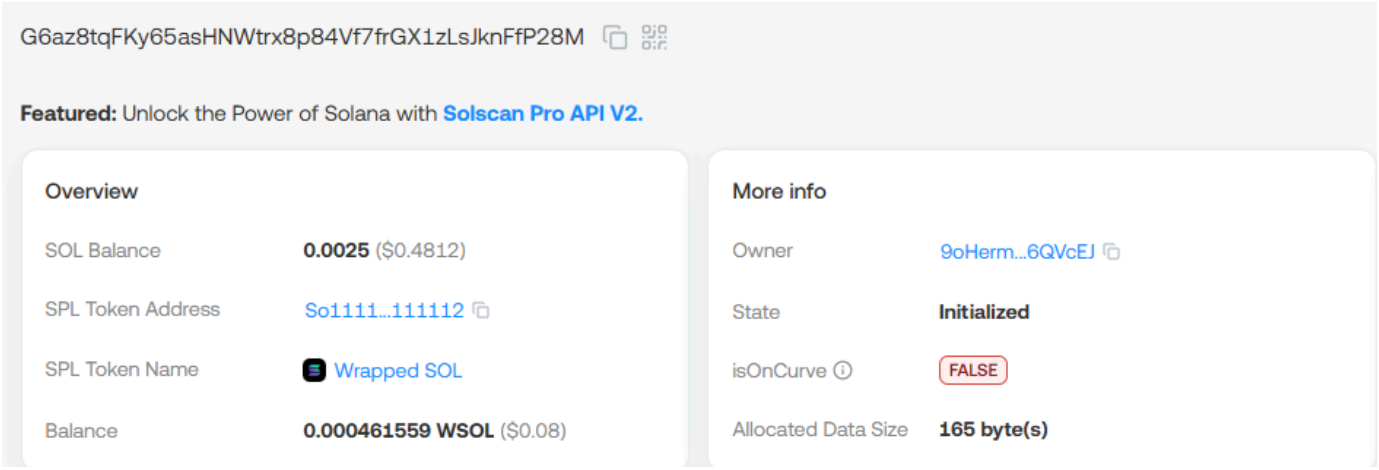
Once funds are deposited, they are stored in a **Program Derived Address (PDA)** an account that:

- Is **not controlled by user's private key**

- Has **no private key at all**
- Is **owned by a smart contract**

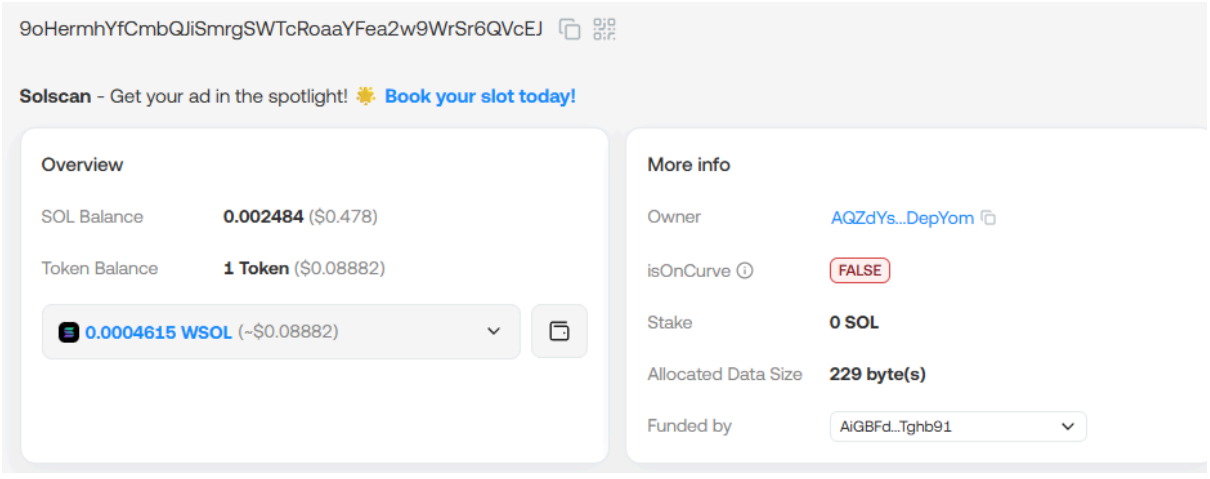
The PDA's behavior is dictated entirely by the contract logic **not user's wallet**. You cannot unilaterally withdraw from it. You don't have signing authority over it. You simply hope the contract behaves as expected.



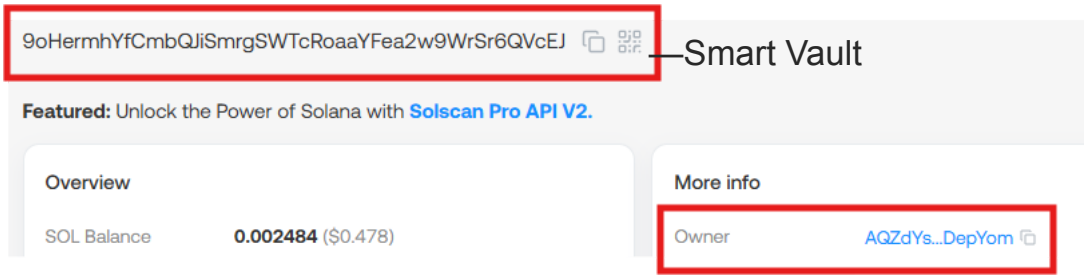


1) Image: Smart Vault address is `isoncurve=false (hence its PDA generated by smart contract, hence have no private key)`

2) `PDA IS owned by some other address -` 9oHermhYfCmbQJiSmrgSWTcRoaaYFea2w9WrSr6QVcEJ (again a PDA not the User deposit wallet)



3) In our Investigation it is found that my own Smart Vault PDA (9oHermhY) and every other user Smart Vault on Luckio platforms were owned by a Smart Contract with address- (AQZdYsg36tEn8ZJ7RKSSLbUSLoGPBi71TCLruCDepYom)



Owner- smart contract

AND This proves that - No, user do not own their smart vault , the program does (AQZdYs).

Other False Claims :

“Your Smart Vault is self-custodial — Luck.io cannot move or freeze your funds.”

“Your funds never leave your control.”

“The vault only recognizes the player's wallet signature.”

“The casino never gains access to your money — not even temporarily.”

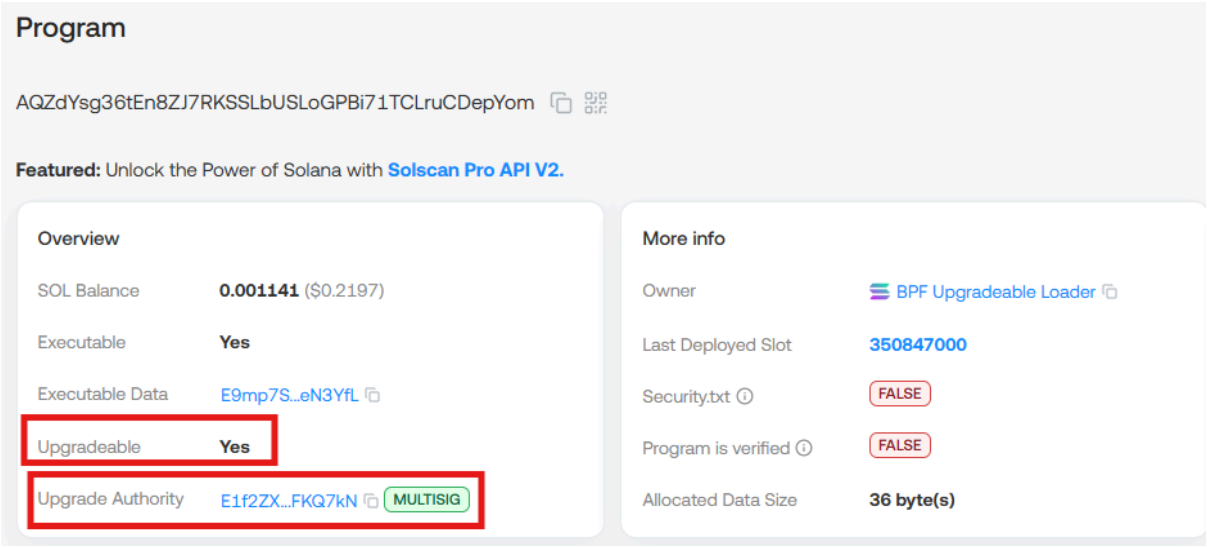
Reality:

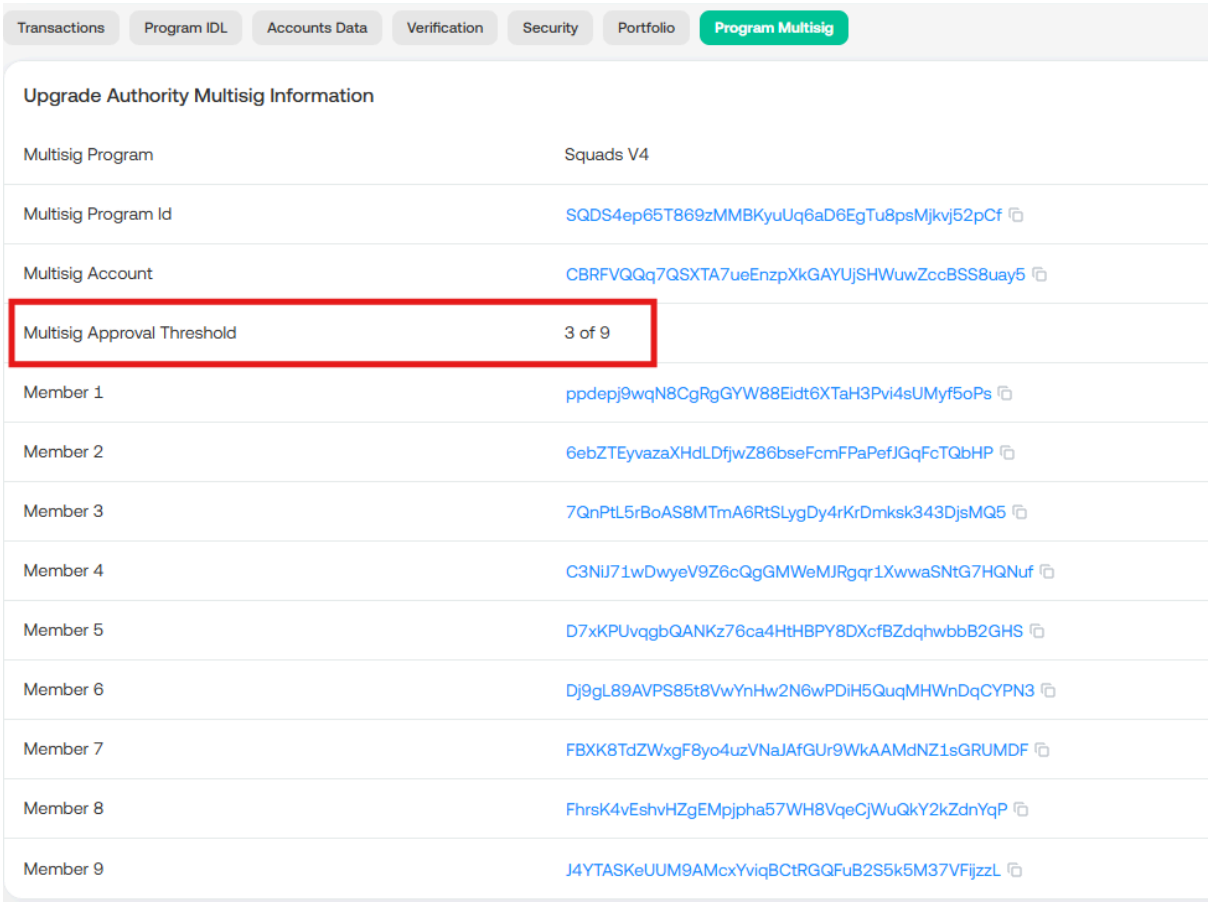
Every User’s Smart Vault is :

A PDA (`isoncurve=false`)

Owned by an **upgradeable smart contract** (`AQZdYs...`)

Controlled by a **3-of-9 anonymous Squads V4 multisig**





What this Means:

The team holds an **upgradeable program authority** over every user's Smart Vault via a **3-of-9 multisig program**.

With just 3 signatures, they can:

- Deploy a new version of the vault contract
- Drain vaults
- Restrict withdrawals
- Freeze sessions
- Delay withdrawals based on arbitrary conditions
- They can temporarily or permanently redirect funds to their own wallets
- can **change the rules** of the vault at any time.

2) Smart Contract & Code Claims

“All transactions are handled by verifiable smart contracts.”

“No human can interfere — the code executes exactly as programmed.”

“Funds can only flow in and out of the Smart Vault from the same wallet that deposited them.”

“Settlement is automatic, instant, and done by smart contracts.”

“The vault contract is fully governed by your wallet.”

“You can interact with the contract directly from any Solana explorer or CLI tool.”

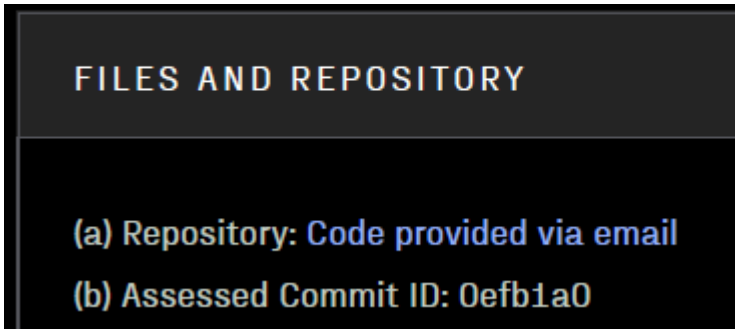
“Luck.io is fully decentralized and accountless.”

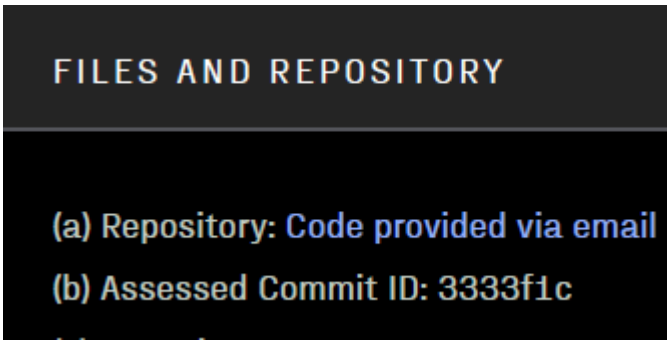
Claim 1: “All transactions are handled by verifiable smart contracts.”

REALITY :

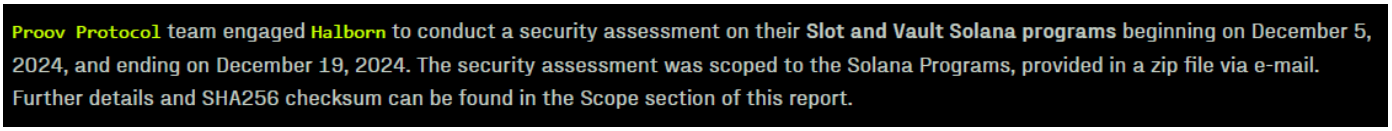
- Yes, transactions are executed through smart contracts **on Solana**.
- But the contracts are **not open-source**.
- The code was sent privately to Halborn via email (not publicly verifiable).
- There’s **no guarantee** the deployed contract matches the audited one.

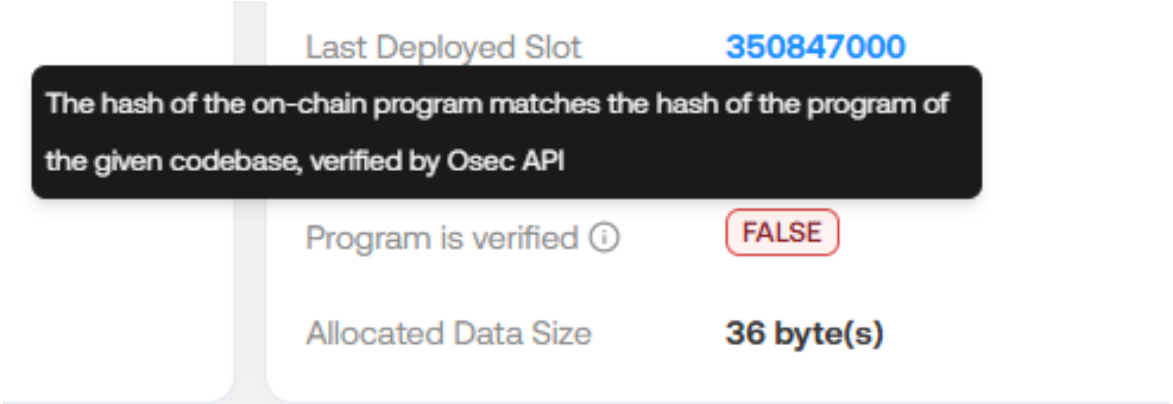
A contract is only “verifiable” if its source code is public and matches the deployed program — neither is true here.





Proof Image: Solscan showing hash of the program audited by Halborn does not matches the hash of the program of the given code base, verified by Osec Api which implies that
The code was **privately shared**, not public. It was **not verified against what was deployed** to the Solana blockchain.





Claim 2: “Funds can only flow in and out from the same wallet that deposited them.”

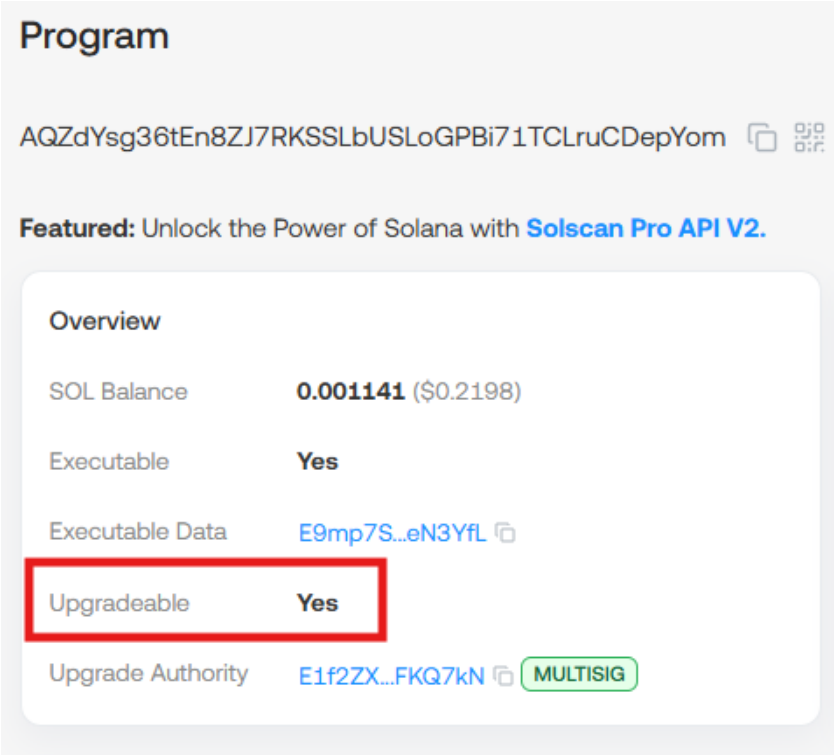
Reality:

There is **no open-source code** or logic published that guarantees this.

Even if that’s how it works **today**, the upgradeable nature of the program means it could be changed.

The team can deploy a new version that routes funds elsewhere.

Proof:



Claim 3: “Settlement is automatic, instant, and done by smart contracts.”

Reality - Partially False

7.6 RELIANCE ON OFF-CHAIN CRITICAL LOGIC

// INFORMATIONAL

Description

The on-chain programs are used for settlement only. Critical actions, such as initiating and accepting bets, determining game outcomes, and settling those outcomes, are handled by off-chain backend servers that are out of scope of this assessment. While the settlement instructions require signatures from all involved backend servers, users must trust that the core logic is correctly implemented and that the backend servers will not collude or misuse their authority.

The Halborn audit confirms that settlement logic is off-chain.

- **Backend-controlled wallets call instructions like `settle_user_gain`, `settle_user_loss`.**

So while smart contracts handle the final transfer, the decision to settle is made off-chain.

Claim 4: “The Smart Vault contract is fully governed by your wallet.”

Reality:

- The vault is a PDA, owned by a contract.
- You’re not the authority or signer for that PDA.
- The contract is governed by a **multisig** upgrade authority, not your wallet.



Claim 5: “Luck.io is fully decentralized and accountless.”

Reality:

- The program is governed by a **centralized multisig**

- The backend performs **critical off-chain actions**

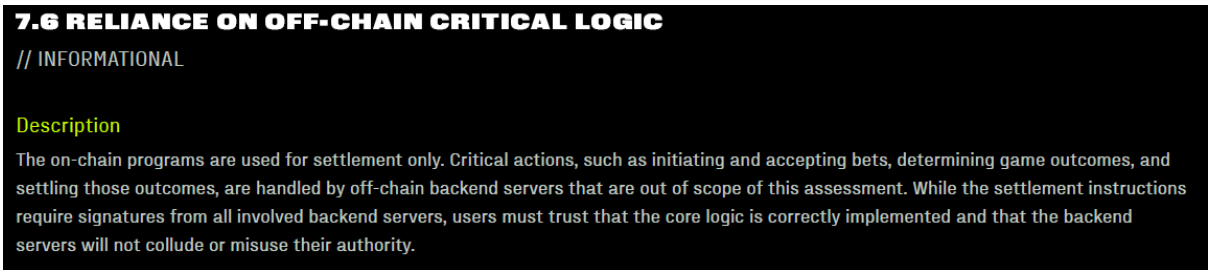
3) **Randomness & Fairness Claims: Reality Check**

Claim 1: “Multiple independent oracles generate randomness and publish their signatures on-chain.”

Reality:

1. **There is no known list of oracles**
2. **No oracle wallet addresses are shared**
3. **No randomness signatures are posted to-chain in any readable or explorable form**

Proof: Audit says backend performs all critical game logic



7.6 RELIANCE ON OFF-CHAIN CRITICAL LOGIC

// INFORMATIONAL

Description

The on-chain programs are used for settlement only. Critical actions, such as initiating and accepting bets, determining game outcomes, and settling those outcomes, are handled by off-chain backend servers that are out of scope of this assessment. While the settlement instructions require signatures from all involved backend servers, users must trust that the core logic is correctly implemented and that the backend servers will not collude or misuse their authority.

Claim 2: “No one — not even Luck.io — can tamper with the results.”

Reality:

- **Luck.io backend submits the result via wallets (unknown oracles) they control**
- **The result is computed off-chain and then sent on-chain**
- **If they wanted, they could:**
    - **Submit a different result**
    - **Delay a result**
    - **Replay randomness**

Summary: Provably Fair or Provably Centralized?

After a comprehensive on-chain investigation into **Luck.io's core infrastructure**, marketing claims, audit reports, and program ownership structure, we found that **many of Luck.io's most critical claims are either misleading, unverifiable, or provably false.**

Custody Isn't Real Custody

Despite branding itself as **non-custodial**, Luck.io's Smart Vaults are **Program Derived Addresses (PDAs)** controlled by an **upgradeable smart contract** not by the user's wallet. These contracts are governed by a **3-of-9 anonymous multisig**, meaning:

- The team can **change the vault logic at any time**
- Withdrawals and vault behavior are not guaranteed
- You don't own or control your vault , the contract does

Code Isn't Verifiable

The smart contract code governing Luck.io:

- Is **not open-source**
- Was shared privately with Halborn via email
- Has **not been verified** against what's actually deployed on-chain

This makes their promise of "verifiable smart contracts" and "trustless logic" a **claim without cryptographic proof**.

Fairness Isn't Provable

The so-called **"Provably Fair"** system is powered by the proprietary **Proov Protocol**, which:

- Is **closed-source**
- Has **no visible randomness proofs or oracle signatures**
- Relies on **backend-controlled wallets** to trigger results

Despite claiming “multiple independent oracles” and “on-chain randomness,” all game outcomes are handled off-chain meaning **Luck.io retains full control over wins, losses, and randomness**.